

1.Cookies a sessions – účel, obsah, tracking

Cookies

- Co to je?
 - Malé množství dat uložené v prohlížeči uživatele
 - Nastaví se přes HTTP hlavičku Set-Cookie a zpět v Cookie
 - Max 4KB, max 50 na doménu
- Proč?
 - Řeší bezstavovost HTTP protokolu (každý požadavek je nezávislý)
 - Uchovává stavy mezi požadavky (autentizace, personalizace, tracking)
- Historie
 - 1994 Lou Montulli v Netscape
 - Původně elektronický nákupní košík
 - 1997 první oficiální specifikace
 - 2011 aktuální standard (dnes v každé webovce)
- Atributy
 - Domain, Path (pro které cesty na doméně), Expires, Max-Age (preferováno), Secure (posíláno pouze přes HTTPS), HttpOnly (nelze zobrazit v JS)
 - SameSite – ochrana proti CSFR útokům
 - CSRF = využije přihlášeného uživatele k provedení nechtěných změn
 - =Strict – neposílá nikdy při cross-site požadavku, bezpečné, možné zhoršení uživatelského komfortu
 - =Lax – posílá jen při navigaci GET ne při POST, výchozí hodnota, kompromis bezpečnost X použitelnost
 - =None – posílá se vždy, vyžaduje Secure, nutné pro cross-site functionality

- Typy
 - First-party – vytvořené právě navštěvovanou doménou, autentizace a preference, obecně nutné
 - Third-party – vytvořené jinou doménou, tracking napříč weby, postupně blokové prohlížeči
 - Session (dočasné) – nemají Expires/Max-Age, smažou se po zavření prohlížeče, přihlášení
 - Persistent (trvalé) – mají Expires/Max-Age, uložené v prohlížeči, dlouhodobé preference jako je jazyk, theme, ...
- Použití
 - Autentizace a session management
 - Nejčastější použití
 - Server vytvoří po přihlášení session ID, ukládá se do cookie s atributy HttpOnly, Secure, SameSite=Strict
 - Server uchovává session data, při každém požadavku se ID validuje
 - Session ID je náhodný řetězec
 - Omezená doba platnosti
 - Personalizace
 - Uživatelské preference
 - Jazyk (lang=cs), vzhled (theme=dark), eshop košík, poloha v dlouhém formuláři
 - Rychlé, i bez přihlášení
 - Analytika a tracking
 - Výhody – sledování chování, optimalizace UX, A/B testování, měření konverze
 - Nevýhody – soukromí uživatelů, nutnost souhlasu GDPR, blokování, etické otázky

- GDPR a cookies
 - Cookies jsou osobní údaje
 - Nutný explicitní souhlas před nastavením, výjimka autentizace a bezpečnost
 - Uživatel musí mít možnost odmítnout a vědět co dělají a jak dlouho
 - Moderní přístup k souhlasu – kategorizace, granulární kontrola, odmítnutí stejně těžké jako přijetí, nástroje: Cookiebot, OneTrust
 - Konec third party cookies – posun směrem k privacy-first webu, alternativy: Privacy Sandbox, FLoC, Topisc API
- Moderní alternativy
 - Web Storage API
 - localStorage – v prohlížeči bez expirace, 5-10MB, pouze z JS, neposílá se automaticky serveru
 - sessionStorage – data se smažou po zavření tabu
 - **Není bezpečné proti XSS útokům!**
 - IndexedDB
 - Výkoná DB v prohlížeči
 - Desítky až stovky MB
 - Strukturované ukládání
 - Asynchroní API
 - Vhodné pro offline aplikace, PWA
 - Složitější API než Web Storage
 - JWT (JSON Web Tokens)
 - Moderní alternativa k session cookies
 - Token obsahuje všechna data (stateless)
 - Je podepsaný serverem, ukládá se do localStorage nebo cookie
 - Výhody: škálovatelnost, microservices-friendly
 - Nevýhody: nelze jednoduše zneplatnit, větší velikost
 - Skládá se ze 3 částí oddělených tečkou Header, Payload, Signature

- Best practises
 - Vždy HTTPS (Secure atribut)
 - Nastavit HttpOnly a SameSite atributy
 - Minimální platnost, neukládat citlivá data, regenerovat session ID, respektovat GDPR
- Shrnutí
 - Cookies řeší bezstavovost HTTP protokolu
 - Správné nastavení atributů je klíčové pro bezpečnost
 - HttpOnly, Secure, SameSite chrání proti útokům
 - GDPR vyžaduje souhlas uživatele s nenutými cookies
 - Third-party cookies jsou postupně rušené
 - Moderní alternativy: Web Storage, IndexedDB, JWT
 - Používejte best practices pro bezpečné webové aplikace
- Příklad

```

                                Bezpečná session cookie
Set-Cookie: __Host-session=abc123xyz;
  Path=/;
  Secure;
  HttpOnly;
  SameSite=Strict;
  Max-Age=1800

```

- Prefix __Host - zajišťuje, že cookie musí mít Secure, Path=/, bez Domain
- Všechny bezpečnostní atributy nastavené
- Krátká doba platnosti (30 minut)
- Vhodné pro moderní webové aplikace
- Moderní prohlížeče podporují cookie prefixy pro zvýšení bezpečnosti
 - __Secure – Vyžaduje Secure atribut
 - __Host – Vyžaduje Secure, Path=/, žádný Domain, nejpřísnější forma, zamezuje subdomain cookie tossing útokům